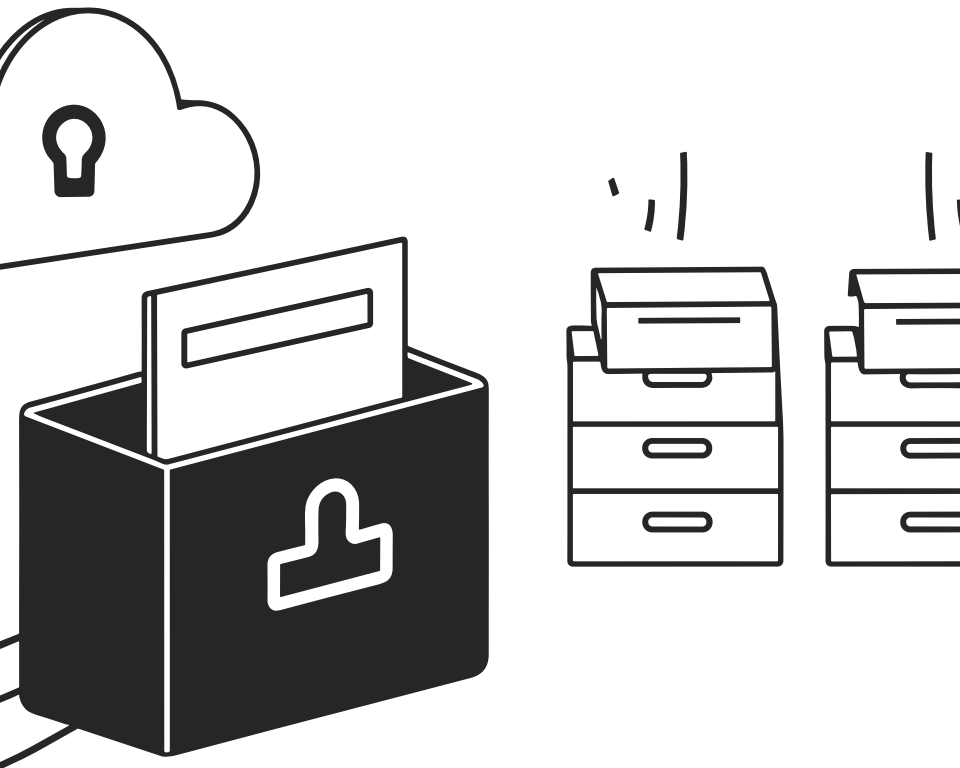




R2M5 — Autenticació i funcionalitat protegida

Microrepte de la sessió **R2S5** · RA avaluat: **RA4** (CA: RA4.d, RA4.e)

SEGURETAT WEB

AUTENTICACIÓ

SESSIONS

Tres conceptes clau

Abans de programar, cal entendre la diferència entre aquests tres termes fonamentals de seguretat.

Identificació

L'usuari **diu qui és**: proporciona un nom d'usuari, correu o identificador. El sistema encara no ha comprovat res.

Autenticació

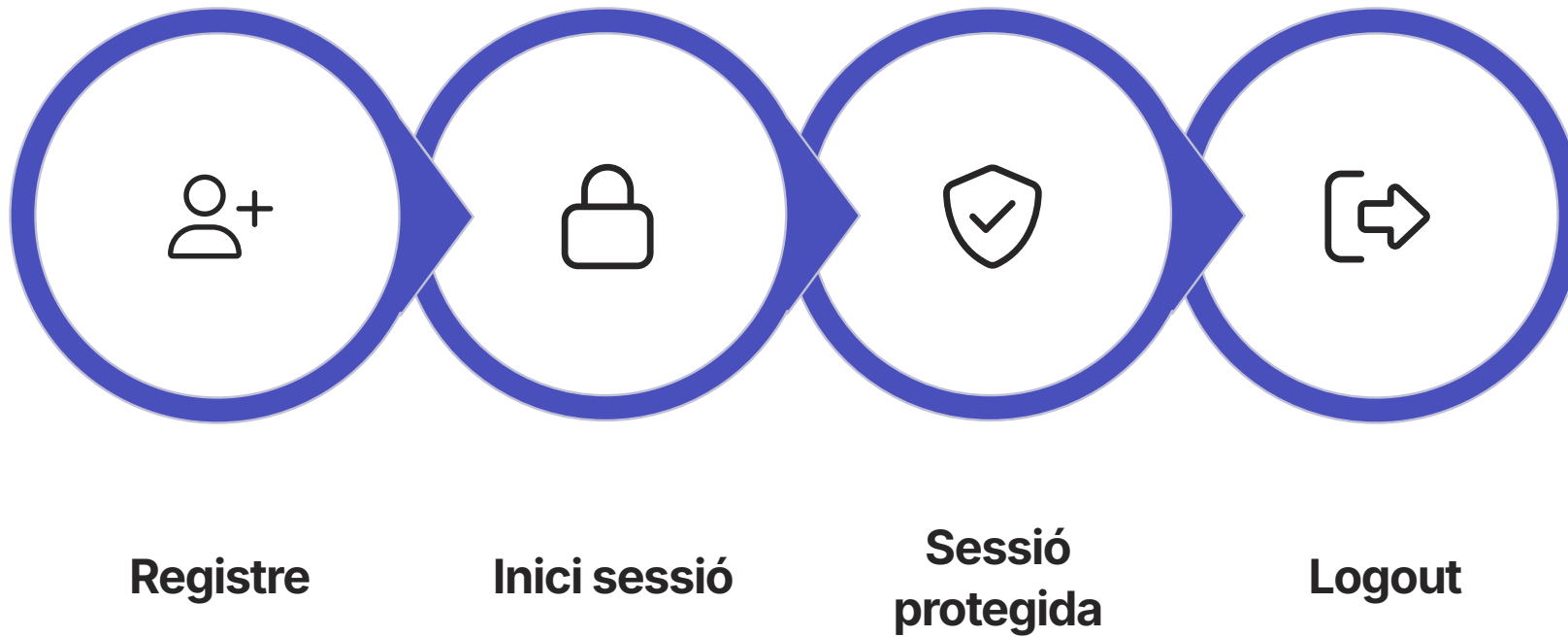
El sistema **verifica** que l'usuari és qui diu ser, comprovant les credencials (contrasenya, token...) al servidor.

Autorització

Un cop autenticat, el sistema decideix **quines operacions** pot fer aquell usuari. Va més enllà del simple login.

Objectiu del microrepte

Implementar un flux complet d'autenticació: des del registre fins al logout, passant per la protecció d'una operació real del domini.



Cap component pot faltar: un sistema parcial no és un sistema segur.

Què has d'implementar

01

Registre mínim

Alta d'usuari guardant les dades en un array, fitxer o estructura equivalent.

02

Contrasenya amb hash

Mai en clar. Utilitza `password_hash()` o equivalent en el moment del registre.

03

Login al servidor

Comprova credencials amb `password_verify()` i desa l'usuari autenticat en sessió.

04

Protegir una operació real

Bloqueja al servidor una acció del domini (no una pàgina buida). Prova cas autenticat i no autenticat. Implementa logout.



Evidències mínimes

Codi font

Registre, login i logout funcionals. La contrasenya ha d'estar hashejada al fitxer o estructura de dades.

Demostració en viu

Prova del flux complet: registre → login → operació protegida → logout → intent sense sessió.

Captura o log

Evidència que la ruta protegida retorna error o redirigeix quan l'usuari **no** està autenticat.





Errors habituals



Contrasenya en clar

Guardar o comparar la contrasenya sense hash és un error crític de seguretat.



Login només visual

Amagar botons al client no protegeix res. La protecció ha d'estar al **servidor**.



Protegir una pàgina buida

L'operació protegida ha de ser una acció real del domini, no una pàgina sense contingut ni lògica.



No provar el logout

Cal verificar que, després del logout, la sessió queda invalidada i la ruta protegida torna a bloquejar.

Límits d'aquest microrepte

Aquest repte té un abast delimitat. El que queda **fora** de l'avaluació:

✗ Fora d'abast

- Rols avançats ni control d'accés per perfil
- OAuth, JWT ni tokens externs
- Registre públic complet amb validació exhaustiva
- Recuperació de contrasenya
- Base de dades ni arquitectura completa

✓ Centra't en fer bé el flux bàsic: registre → hash → login → sessió → protecció → logout. Senzill i correcte val més que complex i trencat.

i Un array o fitxer JSON és suficient com a emmagatzematge per a aquest microrepte.

Checklist final

Comprova cada punt abans de donar el microrepte per acabat.

- ☐ El registre crea un usuari i guarda la contrasenya amb hash
- ☐ El login comprova credencials al servidor amb verificació de hash
- ☐ L'usuari autenticat es desa en sessió
- ☐ Hi ha una operació real del domini protegida
- ☐ La ruta protegida bloqueja l'accés sense sessió
- ☐ S'ha provat el cas no autenticat (ha de bloquejar)
- ☐ S'ha provat el cas autenticat (ha de funcionar)
- ☐ El logout invalida la sessió correctament
- ☐ Cap contrasenya és visible en clar al codi o als fitxers

☐ Si tots els punts estan marcats, estàs llest per presentar les evidències del **R2M5** i optar a l'avaluació de **RA4.d** i **RA4.e**.

